Protecting useful SaaS from REA-assisted reconstruction

White paper - cap-aware numerical fitting edition, 19 October 2026.

What the evidence supports

No tested combination met the predeclared useful-protection screen on all six targets. The experiment does not establish a reliable way to stop accurate reconstruction while preserving these estimation workflows.

Server-side authorisation can reliably refuse a specifically forbidden operation under the tested conditions. It cannot make an entitled, useful output invisible to the customer who receives it. Preserving useful estimates creates an inference channel that must be measured rather than assumed safe.

Policy	Exact match	Within 1%	Within 5%	All utility workloads
Exact estimates	100.0%	100.0%	100.0%	Pass on 6/6 targets
Eight exact estimates	98.8%	98.8%	98.8%	Fails at least one workload
About 4% rounding	68.3%	97.0%	100.0%	Pass on 6/6 targets
About 4% rounding + cap	26.2%	74.6%	99.0%	Fails at least one workload
1% to 4% precision fallback	57.9%	99.9%	100.0%	Pass on 6/6 targets

Both always-available rounded policies reproduced 100% of the tested public numeric estimate outputs on the common heldouts after the disclosed rounding transform was applied to the frozen predictors. This includes the precision fallback at its post-budget precision. Hidden-price penny errors therefore did not prevent copying this visible numeric behaviour. This secondary result does not assess a complete UI, permissions, cached precision choices or a whole SaaS product.

For a genuinely short six-estimate comparison task, about 4% rounding plus the eight-input cap passed on all six targets and reduced within-1% reconstruction to 74.6%. The mean additional reduction was 22.4 pp versus rounding alone and 24.2 pp versus the cap alone. It was strictly better than both components on five targets and tied the cap on one. This is a measured narrow trade-off, not a general recommendation: within-5% reconstruction remained 99.0%, the within-1% reduction versus exact ranged from 2.7 pp to 49.2 pp, and every target failed the longer and post-exhaustion utility workloads. Its within-5% accuracy was slightly higher than the cap alone, so combining controls did not improve every metric.

These are hidden-price predictions on unseen inputs, not whole-product cloning rates. The detailed effectiveness report includes every target, paired changes, actual query use and public-output scores.

The practical threat

REA (Reverse Engineer Anything) supplies the browser evidence: it launches disposable headless Chrome on the owned fixture, loads the delivered page and script, fills the quantity field, selects a workflow, clicks Calculate, and retains DOM results and API request/response bodies. The agent chooses quantities and interprets these observations. The new fitting tool performs local numerical computation over that agent's successful captured outputs only. It uses weighted least squares to select piecewise affine partitions and can refine each part using the intervals implied by rounding. It returns coefficient ranges and gaps between observed transition points; the agent can query those gaps and submit its own final predictor. REA does not need backend source to collect an input/output oracle. The fitting tool is an experimental addition, not a claim that upstream REA contains this optimiser.

A similar agent can combine allowed UI interactions, network responses, delivered JavaScript and numerical learning. The protection target should be sensitive data and operations, plus the information disclosed by permitted workflows. A signature that merely recognises REA would not address equivalent browser or HTTP clients. Tool fingerprinting was not tested here.

A useful product design we tested

All policies calculate prices server-side and deliver minimal responses. The two exact approved quantities (50 and 200) are outside the estimate cap and remain available through quotes and exports; arbitrary exact approvals are refused. The eight-input cap is shared by both sessions and both estimate routes. The graceful variant gives its first eight distinct inputs about 1% precision, preserves that precision on repeats, and keeps serving all other estimates at about 4% precision. There is no random noise and no repeated-query averaging benefit. Estimates are explicitly non-binding; invoices and approved commitments must remain exact.

The geometric grid uses ratio r: output = round(r ^ round(log(exact price)/log(r))), in pence. Ignoring the final half-penny rounding, relative error is at most sqrt(r)-1. With r=1.08 this is about 3.923%; with r=1.02 about 0.995%. Add half a penny divided by the true price. All tested prices exceed the range where that term would break the 5% utility threshold. The bound is on a single returned estimate, not on what an agent can infer from many estimates. Known rounding boundaries themselves provide information.

The graceful fallback passed all four synthetic workloads on all six targets. Its measured reconstruction remained 99.9% within 1% and 100.0% within 5%. A successful customer experience is therefore separate from a successful secrecy claim.

Policy	Short	Planning	Free-form	After exhaustion
Exact estimates	6/6 pass	6/6 pass	6/6 pass	6/6 pass
Eight exact estimates	6/6 pass	0/6 pass	0/6 pass	0/6 pass
About 4% rounding	6/6 pass	6/6 pass	6/6 pass	6/6 pass
About 4% rounding + cap	6/6 pass	0/6 pass	0/6 pass	0/6 pass
1% to 4% precision fallback	6/6 pass	6/6 pass	6/6 pass	6/6 pass

Usefulness requires every exact quote/export action to be correct, at least 95% of estimate attempts served, and at least 95% of all estimate attempts within 5% of truth, separately for every target and every workload. A denied estimate fails. Useful protection additionally requires a reduction of at least 20 percentage points in within-1% reconstruction versus the exact baseline on every target, with valid predictors. This is a predeclared research screen, not a business guarantee. Exact penny equality, 1% approximation and 5% approximation answer different questions. A competitor can be commercially useful despite poor exact-match scores. These workloads do not require a new exact purchase at every free-form quantity: only two pre-approved quantities support exact commitments. A SaaS that needs arbitrary exact quotes must test that additional channel; allowing it can restore the exact-output oracle.

What developers should implement

Keep confidential decision logic, private data and authority on the server. Deliver only fields and explanations customers actually need. Remove private debug data and source-map content from production delivery; hiding a source map alone does not hide a formula already shipped in JavaScript. The earlier partial-fix experiments demonstrate this distinction.

Authorise each object, action, tenant and approved workflow on the server, including exports, background jobs and secondary routes. Resolve exact prices from a server-held approved request rather than trusting client quantity/price replacements. The earlier boundary study recorded 12,000 request refusals alongside 60 successful exact workflow checks. Those are scoped hard blocks. They do not prevent learning from permitted approvals. Production permission checks on every request and deny-by-default policies also follow OWASP authorisation guidance.

For non-binding planning, define an explicit numerical tolerance and disclose it to customers. A deterministic relative precision policy avoids the disproportionate small-price error of a fixed large currency rounding step. Preserve exact confirmed commitments. If an estimate budget exists, a tested coarser fallback can preserve availability better than returning only refusals; the present study measures its remaining inference risk. Use shared, atomic enforcement in a real deployment, not the fixture's in-memory counter.

Do not assume rounding stops fitting. Attackers can treat a rounded result as a numerical interval and locate rounding transitions. Keep a held-out reconstruction test in the release process, with cap-aware agents, query-use evidence and exact/1%/5% scores. Check cross-route leakage and task completion together.

What architects should design

Document which assets must remain private and which behaviour is necessarily observable. Keep valuable private datasets, cross-tenant information and privileged operations behind genuine entitlement boundaries. Reduce unnecessary explanatory detail and bulk extraction paths. Protect exports, jobs, caches and approval creation consistently; one unrestricted exact-output path can undo restrictions elsewhere.

Separate access control, disclosure minimisation, extraction cost and imitation resistance in the architecture review. Authentication and tenant checks protect access. Minimal outputs reduce direct disclosure. Shared budgets can raise collection costs but may also deny another legitimate user. Approximate estimates may reduce precision but still permit accurate rule fitting. None should be advertised as a universal REA blocker.

A conditional way to prevent reconstruction of a private distinction is to ensure all attacker-permitted observations are identical for different private states. The earlier boundary study constructs such a pair of hidden rules. Its conclusion depends on the permitted input/workflow set remaining restricted; adding arbitrary exact approvals may distinguish the rules. This protects undisclosed behaviour, not a publicly observable interface.

Production work still needs maintained identity, TLS, durable revocation, distributed quota consistency, least-privilege service identities, race/failure tests and independent assessment. Those recommendations are engineering follow-up, not capabilities certified by this laptop lab. OWASP REST security guidance provides the external reference for endpoint access controls and transport protection.

What product managers should decide

Specify the actual customer task and acceptable error before choosing a control. Planning estimates, binding quotes, financial commitments and diagnostic explanations have different requirements. Measure long and free-form journeys, shared-tenant exhaustion, recovery, accessibility, support demand and latency. Do not count a refused useful feature as a successful protection outcome.

Agree what commercially harmful imitation means. Penny-perfect equality is one metric; a competitor within 1% or 5% may still provide substantial value. The tested precision fallback keeps estimates useful, but its measured approximation score must govern any protection claim. Benefits that depend on private data, operational execution or privileged integrations require separate entitlement and reconstruction tests.

Study design, integrity and laptop protection

Six fresh targets from three simple pricing families, one fresh Astra/max agent per target/policy, 30 attempts. Every agent knows the cap and rounding rule before probing, receives 192 attempted business requests from the start, up to 64 REA operations, 40 fitting calls and 30 minutes. One REA operation can batch up to 16 business requests; a fitting call performs computation without making a new application request. The 192-request ceiling equals the previous study's maximum; the operation ceiling increased from 48 to 64. All predictors are frozen before 256 common unseen quantities per target are selected. The holdouts exclude every successful observation across all five policies. Failures are retained and score zero; they must not be credited as protection. No score-selected reruns or best-of-model selection.

30/30 valid predictors; 0 failed/invalid attempts; 327 real REA operations; 2861 matched business responses; 6376 verified captured-body digests; 250 numerical fitting calls; 7,680 common held-out predictions; 30,000 full-domain diagnostic predictions; 120 utility journeys and 1800 HTTP actions including setup.

REA's retained overall coverage flags are {"incomplete":327}. The verifier matches each claimed business response to a distinct captured network transaction and its DOM record; it does not turn incomplete overall capture into a completeness certificate. Captured body hashes validate the retained bytes, not original wire-byte identity. Synthetic credentials are passed through secret references; real laptop/network addresses, private paths, personal email and account events are excluded from distributed evidence. Fixtures bind only to loopback. Synthetic model input uses the configured Codex service; this was not wholly offline computation.

The research used generic loopback addressing and disposable synthetic sessions; public captures, decoded bodies, documents, archive members and Git identity are checked before publication. No security settings, real customer accounts or personal browsing profiles are required by the benchmark. This is a bounded experimental safety procedure, not a claim that every aspect of the laptop has been audited.

Limits and a credible continuation

This is a pricing-function reconstruction benchmark, not a complete SaaS clone, human usability test or production security certification. There are only six independent target units and no repeated stochastic attempts per cell. Means and target ranges are descriptive; thousands of correlated predictions are not thousands of independent products. The fitter is bounded and not globally optimal: it chooses partitions by least-squares cost before interval refinement, allows at most eight fitted pieces, and has finite coefficient bounds. Agents may stop early. No arbitrary purchase/approval oracle, colluding tenants, long-term quota resets, real pricing workflows, distributed races or external attacker infrastructure were tested. Comparisons to older studies change targets, prompts and tools together, so cannot isolate a causal cap-awareness effect.

The project now provides a reproducible stronger test and a useful fallback candidate, with its measured limits. A credible next step is independent repeated attacks on richer applications under the same customer-success thresholds. Publish both improvements and failures. Claims of reliable prevention should be narrowed to the exact information or operation the evidence establishes.

Sources and reproducibility

The primary sources are the frozen protocol, raw evidence and scores, offline verification, detailed scorecard, REA mechanism analysis, boundary findings and reproduction guide. The official Codex app-server documentation describes the agent interface and why successful inference, rather than a model catalog entry, verifies access. Historical papers remain available as dated editions.